

Aree di testing per la tesi OCaml

Dominio OCaml	Task da generare	CWE critiche da cercare	Perché conta
Web backend	Parsing delle request, validazione dell'input, endpoint JSON, autenticazione e costruzione delle query	CWE-20, CWE-79, CWE-89, CWE-22, CWE-306	Il web espone input non fidati e produce output destinati a browser, servizi o database.
Web frontend / js_of_ocaml	Rendering HTML, gestione dei form, escaping, cookie e stato lato client	CWE-79, CWE-116, CWE-352, CWE-200	Il rischio principale riguarda output non correttamente escapato e manipolazione dello stato lato client.
Networking / protocol parsing	Parser di pacchetti, gestione degli header, framing, timeout e controlli dei limiti	CWE-20, CWE-125, CWE-131, CWE-400	I parser di rete sono particolarmente sensibili a input malevoli, dimensioni inattese e consumo eccessivo di risorse.
MirageOS / unikernel	Configurare un servizio TLS/HTTP/DNS, parsing di richieste, gestione dei certificati, file upload, gateway/firewall e accesso a storage remoto	CWE-20, CWE-22, CWE-79, CWE-94, CWE-295, CWE-330, CWE-434, CWE-502	MirageOS opera su rete e infrastruttura con l'obiettivo di ridurre la superficie di attacco; input handling, TLS, configurazioni e deserializzazione sono quindi i punti più delicati.
Sistemi / filesystem	Gestione dei path, file temporanei, upload, decompressione e sandboxing	CWE-22, CWE-73, CWE-59, CWE-434	Le superfici tipiche includono path traversal, race sui file, symlink e caricamento di tipi di file pericolosi.
Process execution / automation	Invocazione di comandi, pipeline, hook di build e wrapper della shell	CWE-78, CWE-88, CWE-94, CWE-77	È uno dei punti più esposti a injection, abuso dei comandi e costruzione non sicura degli argomenti.
Randomness / crypto support	Generazione di token, ID di sessione, nonce, codici di reset e password	CWE-330, CWE-338, CWE-326	La generazione debole o prevedibile di valori casuali è un asse utile per confrontare la sicurezza del codice generato.
Serializzazione / deserializzazione	Marshal, JSON, caricamento di configurazioni, formati binari e ricostruzione di oggetti	CWE-502, CWE-915, CWE-913	La deserializzazione di dati non fidati può introdurre ricostruzione arbitraria di oggetti, modifica dello stato e comportamenti inattesi.
Concorrenza / async	Stato condiviso, cancellazione, race condition, ordinamento dei lock e message passing	CWE-362, CWE-667, CWE-833	La programmazione funzionale riduce parte del rischio, ma restano possibili errori di coordinamento, deadlock e corse sui dati.
Finance / business logic	Pricing, validazione degli ordini, aggiornamento del ledger, arrotondamenti e invarianti	CWE-20, CWE-682, CWE-807, CWE-908	In questo dominio emergono soprattutto errori di logica, validazione insufficiente e uso scorretto dei confini di fiducia.
Formal methods / DSL	Trasformazioni dell'AST, builder type-safe, interpreti e prover	CWE-94, CWE-95, CWE-20	Il rischio principale non riguarda la memoria, ma trasformazioni insicure, interpretazione di input e generazione interna di codice.
Tooling / compiler / static analysis	Visitor dell'AST, generatori di codice e trasformazioni source-to-source	CWE-94, CWE-20, CWE-703	Questo ambito consente di confrontare direttamente la sicurezza della generazione e trasformazione automatica del codice.
Embedded / safety-critical	Input da sensori, calibrazione, macchine a stati e interfacce di protocollo	CWE-20, CWE-190, CWE-682, CWE-369	Il focus è sulla robustezza degli invarianti, sulla gestione numerica e sulla validazione degli input in sistemi con conseguenze operative.